EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

DEF-BSLNCNFG

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Scope and Compliance Requirements
3. Baseline Configurations
3.1 M365 GCC High
3.2 Windows Partitioned Systems
3.3 iOS Devices
3.4 Android Devices
4. Essential and Non-Essential Components
4.1 Ports and Protocols
4.2 Services
4.3 Programs
4.4 Functions
5. Common Security Settings
5.1 Malware Protection
5.2 Essential Capabilities
6. Documentation

DEF-BSLNCNFG

1. Purpose

This document defines the baseline configurations for organizational systems, including Windows OS environments, in compliance with NIST SP 800-171, DFARS 7012, and CMMC 2.0. The purpose of establishing baseline configurations is to ensure a consistent and secure operating environment that minimizes cybersecurity risks, ensures compliance, and facilitates ongoing system monitoring and audits.

2. Scope and Compliance Requirements

This baseline configuration applies to the respective systems in scope. The baseline configurations are aligned with the following security standards and policies:

- NIST SP 800-171r2 – Protecting Controlled Unclassified Information (CUI) .
- DFARS 7012 – Cybersecurity requirements for defense contractors.
- CMMC 2.0 – Cybersecurity Maturity Model Certification .

3. Baseline Configurations

3.1 M365 GCC High

3.1.1 Essential Services

- TCP/443 (HTTPS) is required for all connections to M365 GCC High services
- TLS for all connections
- Access restricted to Microsoft Entra ID authenticated users only
- All Apps that are available in the licenses assigned to the respective user is essential except the application Whiteboard in M365 GCC High
- Idle session timeout set to maximum 60 minutes per POLICY-CMPNYVAL
- Conditional access policies:
  - Block access from non-managed and non-compliant devices
  - Require multi-factor authentication for all users

3.2 Windows Partitioned Systems

3.2.1 System Hardening

- Device restrictions baseline applied via Microsoft Intune
- Essential Capabilities are the remaining features after the baseline is applied
- No mobile code is authorized as enforced by Microsoft Intune.
-

Windows defined Intune security baselines (based off the linked vendor-defined baseline) enforced with settings including:

- Windows Defender enabled with real-time protection
- SmartScreen enabled for reputation-based protection
- Potentially unwanted application (PUA) protection enabled
- Block untrusted and unsigned applications from removable media (USB/external devices)
- Credential Guard enabled
- Block local administrator accounts

3.2.2 Encryption

- BitLocker required on all Windows systems
- This requirement explicitly extends to the non-CUI partition on any device split between the GCC High enclave and a commercial environment
- FIPS 140-2 validated modules for encryption
- Recovery keys managed through Microsoft Intune

3.2.3 Device Control

- USB storage devices blocked except for whitelisted and authorized
- External media devices blocked except for whitelisted and authorized
- Administrative privileges restricted

3.2.4 Devices - Firmware

- Firmware checked and updated quarterly
- Critical firmware updates applied immediately upon release as part of Windows Updates

3.3 iOS Devices

3.3.1 Hardening

- Essential Capabilities are the remaining features after the baseline is applied.
- All Microsoft Applications are essential programs.
- Follows the Apple iOS/iPadOS 17 BYOAD Security Technical Implementation Guide: Version 1, Release: 1 Benchmark Date: 07 Feb 2024
- AIOS-17-800020 – EMM (Intune MAM) supports autonomous monitoring and compliance validation.
- AIOS-17-800030 – Conditional Access Policies enforce compliance before access.
- AIOS-17-800040 – Jailbreak detection is active in MAM policies.
- AIOS-17-800050 – Apps are pre-vetted; known malicious apps are blocked.
- AIOS-17-800070 – Continuous monitoring is in place.

- AIOS-17-800080 – Jailbroken devices are blocked; MAM apps wiped if necessary.
- AIOS-17-800090 – non-approved apps or stores trigger blocking actions.
- AIOS-17-800100 – Minimum OS version enforced (iOS 17.6.1).
- AIOS-17-800110 – Conditional Access restricts access to approved DOD systems.
- AIOS-17-800120 – Policy controls protect personal and organizational data separation.
- AIOS-17-800130 – Only managed data/apps are wiped on revocation/loss.
- AIOS-17-800200 – Intune MAM is NIAP compliant.
- AIOS-17-800210 – User agreement describes data monitoring and collection.
- AIOS-17-800220 – Personal devices permitted per facility policy.
- AIOS-17-800230 – Camera/mic policy handled via facility procedures.

3.3.2 Encryption

- Built-in iOS encryption (256-bit AES) enforced through Microsoft Intune
- All Microsoft Applications are essential programs.
- Data protection enabled for all Microsoft applications.
- Organization data encryption required
- Microsoft Intune App Protection Policies implemented:
  - Block backups of organization data
  - Data transfer limitations:
    - Restrict web content transfer to Microsoft Edge only
    - Block third-party keyboards
    - Block sync of managed app data with native apps or add-ons

3.3.3 Endpoint Security

- Jailbreak detection enabled with block access enforcement
- Security configurations enforced through Microsoft Intune
- Conditional launch settings:
  - Block access after 5 PIN attempts
  - Block access after 720 minutes offline (block access)
  - Wipe data after 90 days offline
  - Block access for disabled accounts

3.4 Android Devices

3.4.1 Hardening

- Essential Capabilities are the remaining features after the baseline is applied.

- Latest Android version required (minimum Android 9.0+)
- Device enrollment through Microsoft Intune required
- App Protection Policies enforced for managed apps:
  - com.groupdclists.android
  - com.microsoft.d365.fs.mobile
  - com.microsoft.rdc.android
  - com.microsoft.stream
  - com.ricohsmartspaces.app
- Device access controls:
- PIN required for access (minimum 4 digits)
- Numeric PIN type
- Simple PIN allowed
- Biometrics allowed with PIN override after timeout
- 30-minute timeout (inactivity)
- PIN recheck after 30 minutes of inactivity
- Maximum 5 PIN attempts before reset

3.4.2 Encryption

- Organization data encryption required and enforced through Microsoft Intune
- wolfSSL-based 256-bit AES FIPS 140-2 validated encryption for Android devices
- Data protection settings:
- Block backups of organizational data
- Block saving copies of organizational data except to OneDrive for Business and SharePoint
- Restrict cut, copy, and paste between apps to policy managed apps with paste in
- Printing of organizational data blocked
- Organization data notifications allowed
- Screen capture and Google Assistant disabled

3.4.3 Data Transfer Controls

- Data transfer to applications restricted:
- Allow telecommunications data transfer to any dialer app
- Allow messaging data transfer to any policy-managed messaging app
- Allow receiving data from all apps
- Block synchronization of policy managed app data with native apps or add-ins

3.4.4 Endpoint Security

- Root detection enabled with block access enforcement
- Security configurations enforced through Microsoft Intune
- Conditional launch settings:
- Block access after 5 PIN attempts
- Block access after 720 minutes offline
- Wipe data after 90 days offline
- Block access for disabled accounts
- Block access for jailbroken/rooted devices
- Device lock required (low complexity)
- Block access for devices with low threat level

3.4.5 Application Access

- All managed applications must access content through Microsoft Edge browser
- Web content transfer restricted to Microsoft Edge
- Offline grace period: 720 minutes before blocking access
- Device targeting applies to all Android device types in the Enclave

4. Essential and Non-Essential Components

4.1 Ports and Protocols

- Essential Ports and Protocols
  - HTTPS (TCP port 443)
  - DNS (UDP/TCP port 53)
  - NTP (UDP port 123)
  - SSH (TCP port 22)
  - TLS 1.2+ for all encrypted communications
- Non-Essential Ports and Protocols
  - FTP

4.2 Services

- Essential Services
  - Microsoft Defender for Endpoint (HTTPS)
  - Microsoft Intune (HTTPS)
  -

Microsoft 365 GCC High services (HTTPS)
    - Duo authentication service (HTTPS)
    - Cloudflare network services (HTTPS)
- Non-Essential Services
    - FTP

4.3 Programs

- Essential Programs
    - Microsoft Office 365 applications
    - Microsoft Teams
    - Microsoft Edge browser
    - Duo application
    - Cloudflare WARP client
    - Microsoft Defender for Endpoint client
    - Automox for patch management
    - Ad-hoc signed applications that can be requested, installed and approved which are then listed, updated in the Software Inventory
- Non-Essential Programs
    - Gaming
    - Other programs as per the respective baseline

4.4 Functions

- Essential Functions
    - Use Microsoft Office 365
    - Use browser for work purposes
    - Use local file system for work purposes
    - Use Microsoft OneDrive for files/folders syncing
    - Use Microsoft Outlook for work email access
    - Use Cloudflare, Automox, Duo for device management purposes
    - Use Microsoft SharePoint and DoD SAFE for external file sharing as needed
    - Use programs for work purposes
- Non-Essential Functions (based on system capability baseline; functions not disabled are essential)
    - Personal email accounts
    - Social media applications
    -

Media streaming services
- Unsigned or non-approved applications

5. Common Security Settings

5.1 Malware Protection

- Microsoft Defender for Endpoint required on all applicable systems
- Real-time protection enabled
- Quick scan once weekly
- Update malware definitions every 4 hours
- Cloud-based protection enabled
- Controlled folder access enabled

5.2 Essential Capabilities

- Essential system capabilities are limited to the minimum functions required to support authorized business operations by using Microsoft 365, local system, including user authentication using Duo, Microsoft, data access using Microsoft 365, logging using Azure, and system maintenance/configurations using Intune, Defender, Cloudflare, Duo, Automox.
- Capabilities enabled within the baseline configuration directly support work requirements, such as communication services like Microsoft Teams, Microsoft 365 access like Email, OneDrive and SharePoint, and protection mechanisms necessary for safeguarding Controlled Unclassified Information (CUI) as per this baseline document using Intune, Cloudflare, Duo, Automox, Defender.
- Non-essential software, ports, services, and protocols are disabled to reduce the attack surface and maintain adherence to the principle of least functionality as per this baseline document.
- Only capabilities necessary to enforce security controls such as encryption using BitLocker, auditing using Azure, endpoint protection using Intune, Defender, and centralized configuration management using Intune are permitted within the defined baseline document.

6. Documentation

The documentation will consist of every applicable policy, procedure along with the following documents at the least:

1. System Security Plan (SSP)
2. Network Diagram
3. CUI Data Flow
4. RACI Matrix
5. Asset Inventory (Personnel, Hardware, Software, Location, Documentation)

This baseline configuration document defines the minimum-security standards for all systems within the Exos Aerospace Systems & Technologies, Inc. that process, store, or transmit CUI. Any deviations from these baselines must be documented, risk-assessed, and approved by the *Security Admin* and *Company Admin* following the **SOP-CHNGMGT** procedure.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "DEF-BSLNCNFG".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of DEF-BSLNCNFG (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026